

Podcast 10 — Encryption & Secrets

Podcast 10 — Encryption & Secrets

Length target: 15 min **Repo references:** `domain-1-organizational/17-kms.md` , `18-cloudhsm.md` , `27-acm.md` , `35-secrets-manager.md` , `26-parameter-store.md`

Topic & Scope

Encryption keys + secrets + TLS certificates. KMS is the most-tested security service; the differences between KMS / CloudHSM / Secrets Manager / Parameter Store / ACM are constant traps.

Service Coverage Depth

Deep: - KMS — key types (AWS-managed, customer-managed, AWS-owned), key policies, grants, multi-Region keys, envelope encryption - Secrets Manager vs Parameter Store — when to pick each

Brief but trap-aware: - CloudHSM (when AWS-managed KMS isn't enough) - ACM — public + private CA + import scenarios

Structured Outline

1. **Open (30s)** — “Five services for five different secrets jobs. The traps live in the overlaps.”
2. **KMS (5 min)** — symmetric vs asymmetric, AWS-managed vs customer-managed vs AWS-owned, key policies (root of access), grants, envelope encryption, multi-Region keys, key rotation
3. **CloudHSM (2 min)** — FIPS 140-2 Level 3, single-tenant, customer-managed HSM cluster, when “I need the highest compliance” or “I need to manage keys myself”
4. **ACM (2 min)** — free public certs for AWS services, auto-renewal, ACM Private CA for internal certs, import third-party
5. **Secrets Manager (2.5 min)** — auto-rotation for RDS/DocumentDB/Redshift/custom, cross-account access, \$0.40/secret/month
6. **Parameter Store (2 min)** — Standard tier free, Advanced tier paid, hierarchical, integrates with CloudFormation
7. **Rapid-Fire Trap Drill (60s)**

Must-Mention Exam Tips

- KMS keys: AWS-managed (free, AWS controls policy), customer-managed (you control policy, \$1/month), AWS-owned (invisible)
- Key policy is the ROOT of access — IAM grants alone don't work without key policy allow
- Grants: programmatic, scoped permissions for short-term services (often AWS internal)
- Envelope encryption: KMS encrypts a data key; data key encrypts your data; KMS never sees the bulk data

- Multi-Region keys: same key material across Regions for replicated workloads
- Key rotation: automatic annual for customer-managed; manual for imported key material
- ACM: free public certs, auto-renewal, integrates with CloudFront / ALB / API GW / App Runner
- ACM Private CA: internal certs for private use, hierarchical CAs
- Imported certs in ACM are NOT auto-renewed — track expiry manually
- Secrets Manager: native rotation via Lambda for RDS, DocumentDB, Redshift, custom rotation for others, \$0.40/secret/month + API charges
- Parameter Store: Standard tier free (10k params, 4 KB each, no rotation), Advanced tier \$0.05/param/month (100k params, 8 KB, parameter policies, expiration)
- Parameter Store SecureString uses KMS — but no built-in rotation
- CloudHSM: FIPS 140-2 Level 3, you manage the cluster, single-tenant, integrates with KMS via custom key store

Must-Mention Exam Traps

- EXAM TRAP: Key policy is the AUTHORITY — without an allow there, no IAM grant works
- EXAM TRAP: A customer-managed key with default key policy already trusts the account root — IAM grants then work
- EXAM TRAP: KMS data key is what encrypts your data — KMS never sees the plaintext data
- EXAM TRAP: KMS keys are Region-specific — replicate via multi-Region keys, NOT key sharing
- EXAM TRAP: ACM certs cannot be exported (public) — for export use ACM Private CA or import
- EXAM TRAP: ACM imported certs do NOT auto-renew — set expiry alerts
- EXAM TRAP: Secrets Manager rotation works natively only for RDS / DocumentDB / Redshift — for other secrets you write the Lambda
- EXAM TRAP: Parameter Store does NOT auto-rotate — Secrets Manager does
- EXAM TRAP: Parameter Store Standard is free up to 10k params; for rotation or > 4KB use Secrets Manager
- EXAM TRAP: CloudHSM is single-tenant + FIPS 140-2 Level 3; KMS is multi-tenant + FIPS 140-2 Level 3 (newer keys) — KMS is fine for most compliance unless explicit Level 3 single-tenant requirement
- EXAM TRAP: Cross-account KMS access needs key policy + IAM in user account + grants if scoped
- EXAM TRAP: Some AWS services support only AWS-owned keys (e.g., default S3 SSE-S3) — switch to customer-managed for visibility / policy control
- EXAM TRAP: KMS key deletion has 7–30 day waiting period — schedule + cancel before deletion

Key Decision Matrix

Need	Pick
Encrypt EBS / S3 / RDS / Secrets — managed	AWS-managed KMS key (default)
Custom key policy, cross-account, audit control	Customer-managed KMS key

Need	Pick
FIPS 140-2 Level 3 single-tenant, you control HSM	CloudHSM
Public TLS cert for ALB / CloudFront / API GW	ACM (free, auto-renew)
Private internal TLS certs	ACM Private CA
RDS password rotation	Secrets Manager (native)
API key / OAuth secret with rotation	Secrets Manager (custom Lambda)
App config + non-secret params	Parameter Store Standard (free)
Configuration with > 4 KB or expiration	Parameter Store Advanced
Cross-Region key for replicated data	KMS multi-Region key
Encrypt without seeing data flow through KMS	Envelope encryption (data key)

Tone & Style

- Frame KMS as the foundation; everything else (S3 SSE-KMS, EBS encryption, Secrets Manager) sits on top
- Repeat “key policy is the root of access” multiple times
- Use cost as a deciding factor: Parameter Store free vs Secrets Manager \$0.40/secret

Rapid-Fire Closer

“Key policy or IAM the root?” — “Key policy.” “Auto-rotate RDS password?” — “Secrets Manager.”
 “Free config storage?” — “Parameter Store Standard.” “FIPS Level 3 single-tenant?” — “CloudHSM.”
 “ACM imported cert auto-renew?” — “NO.”